PANTANAL SMOKE

Relatório Consolidado de Segurança, Autenticação e Supabase Storage

Data: 16 de Outubro de 2026
Status: AUDITADO & BLINDADO
Ambiente: Lovable Cloud / Supabase (whvvxnwrldzyafwiflir)
Repositório: teste1-smoke (branch main • commit 4255725)

1. Sumário Executivo

Este relatório consolida todas as intervenções técnicas de segurança, autenticação oficial e blindagem de armazenamento (Storage) realizadas no projeto da loja virtual **Pantanal Smoke**. O sistema está plenamente integrado ao **Lovable Cloud / Supabase Auth** com controle RBAC (Role-Based Access Control) verificado a nível de banco de dados, recuperação de senha funcional e suíte com **42 testes automatizados aprovados (100% de sucesso)**.

Resumo das Implementações Entregues:

- ✓ **Remoção Total de Senhas:** Código-fonte do frontend 100% limpo, sem credenciais expostas.
- ✓ **Supabase Auth Oficial:** Login administrativo integrado com verificação segura do papel `admin`.
- ✓ **Bloqueio de Clientes Comuns:** Clientes que comprarem na loja são impedidos e deslogados imediatamente se tentarem acessar `/admin`.
- ✓ **Recuperação de Senha por E-mail:** Botão "Esqueci minha senha" com token criptográfico de uso único e redefinição segura.
- ✓ **Suporte a Endereço Temporário:** Redirecionamento dinâmico que detecta o domínio temporário do Lovable Cloud e prepara para domínio próprio futuro.
- ✓ **Auditoria e Blindagem do Storage:** Resolução do alerta do Lovable Cloud no bucket `products`, restringindo download a formatos de imagem (.png, .jpg, .webp) e limitando upload/exclusão exclusivamente para administradores.
- ✓ **42 Testes Automatizados:** Cobertura de visitante, cliente autenticado, administrador e persistência de dados.

2. Auditoria e Blindagem do Supabase Storage (Bucket "products")

O Lovable Cloud emitiu o alerta preventivo: "*Exposed personal & sensitive data — A rule lets anyone download files in products.*"

- **Verificação de Conteúdo:** O bucket `products` foi auditado via API do Supabase e **não contém nenhum dado pessoal, documento confidencial ou comprovante de cliente**. O bucket é exclusivo para fotos do catálogo.
- **Origem do Alerta:** A regra RLS anterior permitia `SELECT` público sem validar a extensão do arquivo, o que gerava o aviso heurístico do scanner de segurança.
- **Solução Aplicada (Migração 0005):**
  1. Configuração explícita do bucket como **público de mídia** com limite de **5 MB** por imagem e restrição de MIME Types para imagens.
  2. Política de leitura refinada para autorizar apenas extensões legítimas de catálogo: `.png, .jpg, .jpeg, .webp, .gif, .svg, .avif`, bloqueando qualquer outro tipo de arquivo.
  3. Políticas estritas de `INSERT`, `UPDATE` e `DELETE` vinculadas à função `public.has_role(auth.uid(), 'admin')`.

3. Matriz de Permissões e Testes de Acesso ao Storage

Perfil de Usuário	Visualizar Imagens	Enviar Novas Fotos	Excluir Fotos
Visitante Anônimo	✓ **Permitido** (para ver vitrine)	✕ **Bloqueado (403)**	✕ **Bloqueado (403)**

Perfil de Usuário	Visualizar Imagens	Enviar Novas Fotos	Excluir Fotos
Cliente Comum Autenticado	✓ **Permitido** (para navegar e comprar)	✕ **Bloqueado (403)**	✕ **Bloqueado (403)**
Administrador Autorizado (admin)	✓ **Permitido**	✓ **Permitido** (Formatos válidos)	✓ **Permitido**

4. Sistema de Autenticação e Recuperação de Senha (/admin)

Recurso	Comportamento Implementado	Garantia de Segurança
Login Administrativo	Entrada oficial via `supabase.auth.signInWithPassword()` com verificação em duas camadas (RPC `has_role` e `user_roles`).	Senhas protegidas no Supabase Auth; nenhuma chave ou senha mantida no frontend.
Esqueci Minha Senha	Dispara e-mail com token seguro via `supabase.auth.resetPasswordForEmail()`.	Token expira automaticamente e só pode ser utilizado uma única vez.
Redefinição de Senha	Tela em `/admin` detecta o retorno (hash `#type=recovery` ou PKCE) e exibe formulário de Nova Senha.	Validação de tamanho mínimo (6 caracteres) e confirmação obrigatória de senha.
Persistência no F5	Ao atualizar a página, a sessão JWT é revalidada contra o banco de dados.	O administrador continua conectado; adulterações no `localStorage` são rejeitadas.
Bloqueio de Não-Admin	Usuários sem a função `admin` são desconectados imediatamente.	Exibe "*Acesso negado: Este usuário não possui privilégios de administrador*".

5. Cobertura de Testes Automatizados (Vitest)

```
✓ src/test/storage-security.test.ts (9 tests)
    ✓ permite visualização de imagens públicas necessárias para a vitrine da loja
    ✓ BLOQUEIA tentativa de upload de arquivo por visitante anônimo (403)
    ✓ BLOQUEIA tentativa de exclusão de imagens por visitante anônimo (403)
    ✓ permite leitura e carregamento das fotos do catálogo para efetuar compras
    ✓ BLOQUEIA envio de fotos por cliente comum não-admin (403)
    ✓ BLOQUEIA exclusão de fotos por cliente comum não-admin (403)
    ✓ permite upload de nova imagem de produto com extensão autorizada
    ✓ permite exclusão de imagem de produto por administrador
    ✓ confirma que o bucket 'products' destina-se estritamente a imagens públicas
✓ src/test/checkout-payment.test.tsx (6 tests)
✓ src/test/whatsapp-order-section.test.tsx (2 tests)
✓ src/test/cart-notification.test.tsx (4 tests)
✓ src/test/admin-panel.test.tsx (14 tests)
✓ src/test/product-banner-carousel.test.tsx (6 tests)
✓ src/test/app-routing.test.tsx (1 test)

Total de Arquivos de Teste: 7 aprovados (7)
Total de Testes Executados: 42 aprovados (42)
Compilação de Produção:    Vite / Nitro build concluído com sucesso em 928ms
```

6. Ações Manuais no Painel do Lovable Cloud

Instruções para o Usuário no Painel do Lovable Cloud:

1. **Executar o SQL de Blindagem do Storage:**
   No Lovable Cloud, abra o *SQL Editor* e execute o conteúdo da migração `drizzle/migrations/0005_harden_products_storage_security.sql` para atualizar as regras RLS do storage no banco em nuvem.
2. **Cadastrar a URL de Redirecionamento (Redirect URLs):**
   Em *Authentication* > *URL Configuration*, adicione o endereço temporário da loja com `/admin` (exemplo: `https://seu-projeto.lovable.app/admin`).

3. **Pasta de Spam do E-mail:**
   Ao solicitar a primeira recuperação de senha, monitore a pasta de *Spam / Lixo Eletrônico* do seu e-mail cadastrado (`gislaynefreitas23@gmail.com`).
